FIAP – FACULDADE DE INFORMÁTICA E ADMINISTRAÇÃO PAULISTA
DEFESA CIBERNÉTICA
GRUPO – PURPLEFOX SECURITY

RELATÓRIO TÉCNICO DE TESTE DE INTRUSÃO

Challenge CEAP – Fase 3

Exploração de Aplicação Web – dev.pedreira.org

Alvo Avaliado	dev.pedreira.org
Diretório da Aplicação	/devSecurityG5/
Escopo	Reconhecimento, Análise de Vulnerabilidades Web, Enumeração de Superfície
Ambiente de Teste	Kali Linux (Máquina Virtual)
Ferramentas Utilizadas	Nmap, Nikto, ffuf, dirsearch, OWASP ZAP, Burp Suite, curl, Netcat
Metodologia	OWASP Top 10, CVSS v3.1, PTES
Data do Relatório	29/03/2026
Classificação	CONFIDENCIAL – USO RESTRITO
Compliance Avaliado	LGPD (Lei 13.709/2018), ISO/IEC 27001, NIST SP 800-115

Relatório do 2º Semestre do Curso de Segurança Cibernética — Challenge CEAP

Orientador: Prof. Silvio Cesar Roxo Giavaroto | Coorientador: Coord. André Luis Cirino
Turma: 1TDCOR | 2º Semestre

Participantes

Regis Ramos Pinheiro — RM 567534
Thomás Henrique Pandolfo de Campos — RM 567744
Suzana Maciel da Silva — RM 566914
Dyego de Souza Evaristo — RM 566801
Marcello Paixão da Cruz — RM 567205

AVISO

DOCUMENTO CONFIDENCIAL – USO RESTRITO

Este relatório contém informações técnicas sensíveis sobre vulnerabilidades identificadas. Seu acesso, reprodução, armazenamento, encaminhamento ou divulgação não autorizados são expressamente proibidos e poderão acarretar responsabilização administrativa, civil e penal, conforme a legislação vigente.

SUMÁRIO EXECUTIVO – LEITURA OBRIGATÓRIA PARA O BOARD

O QUE ESTÁ EM JOGO

A aplicação web dev.pedreira.org apresenta um conjunto de fragilidades que, embora individualmente possam parecer de baixo impacto, quando combinadas criam um cenário real e exploitável de comprometimento de sessões de usuários, exposição de dados internos e risco regulatório severo.

Tradução para o negócio:

Imagine um edifício corporativo com câmeras de segurança funcionando (HTTPS ativo), porém com trancas internas ausentes (headers de segurança não configurados), portas abertas entre as salas (cookies sem proteção adequada) e fornecedores externos sem controle de identidade (ausência de SRI). Um invasor não precisa arrombar a estrutura inteira — basta encontrar uma única falha para circular livremente.

A aplicação hoje pode não estar sendo explorada ativamente. Porém, já possui todas as condições técnicas necessárias para que um ataque sofisticado seja bem-sucedido — o que é uma questão de tempo em qualquer sistema web ativo.

Quadro de Vulnerabilidades Identificadas

Vulnerabilidade	CVSS v3.1	Severidade	Compliance
Cookie sem flag HttpOnly (ESR)	**4.0**	**BAIXA/MÉDIA**	LGPD / ISO 27001
Cookie sem atributo SameSite	**4.3**	**BAIXA**	LGPD / ISO 27001
Ausência de Headers de Segurança HTTP	**5.3**	**MÉDIA**	LGPD / ISO 27001
jQuery 1.11.3 com CVEs conhecidos	**6.1**	**MÉDIA**	LGPD / ISO 27001
Ausência de Subresource Integrity (SRI)	**5.0**	**MÉDIA**	LGPD / ISO 27001
Endpoint /metrics exposto sem autenticação	**5.3**	**MÉDIA**	LGPD / ISO 27001

Nenhuma vulnerabilidade crítica isolada foi identificada neste ciclo de testes. Entretanto, a combinação das fragilidades acima cria um cenário encadeado de alto risco, característico de ataques reais bem-sucedidos.

ÍNDICE

SUMÁRIO EXECUTIVO – LEITURA OBRIGATÓRIA PARA O BOARD 3
Quadro de Vulnerabilidades Identificadas 3
ÍNDICE 4
1. ETAPA DE RECONHECIMENTO E VERIFICAÇÃO DE PORTAS 6
1.1 Objetivo 6
1.2 Verificação de Conectividade – Ping 6
1.3 Verificação de Resolução DNS – Nslookup 6
1.4 Varredura de Portas – Nmap 7
1.5 Validação de Conectividade – Netcat 7
1.6 Análise Inicial da Aplicação Web 8
1.7 Comportamento de Redirecionamento e Parâmetro pcaes 8
1.8 Conclusão da Fase de Reconhecimento 9
2. ANÁLISE DE VULNERABILIDADES WEB – OWASP ZAP E BURP SUITE 10
2.1 Visão Geral dos Achados 10
2.2 Vulnerabilidade 1 – Cookies sem Flag HttpOnly 10
Classificação CVSS v3.1 10
O que é e por que importa 10
Vetor de Exploração 11
Impacto Potencial 11
Exposição Legal – LGPD 11
2.3 Vulnerabilidade 2 – Cookies sem Atributo SameSite 11
Classificação CVSS v3.1 11
O que é e por que importa 11
Impacto Potencial 12
2.4 Vulnerabilidade 3 – Ausência de Headers de Segurança HTTP 13
Classificação CVSS v3.1 13
Headers ausentes identificados 13
2.5 Vulnerabilidade 4 – Biblioteca jQuery 1.11.3 com CVEs Conhecidos 15
Classificação CVSS v3.1 15
O que é e por que importa 15
Impacto Potencial 15
2.6 Vulnerabilidade 5 – Ausência de Subresource Integrity (SRI) 17
Classificação CVSS v3.1 17
O que é e por que importa 17
Cenário de Ataque — Supply Chain Attack 17
2.7 Cenário de Desastre vs. Cenário de Remediação 18
3. ENUMERAÇÃO E DESCOBERTA DE SUPERFÍCIE 20
3.1 Objetivo 20
3.2 Linha de Base com curl – Controle de Falsos Positivos 20
3.3 Enumeração com ffuf 21
3.4 Enumeração com dirsearch 22
Análise Crítica do Endpoint /metrics (HTTP 200 – Público) 23
Análise do Endpoint /monitoring (HTTP 401 – Protegido) 24
3.5 Varredura Complementar com Nikto 24
4. FICHA TÉCNICA DOS TESTES 26

4.1 Objetivo 26
4.2 Ambiente de Execução 26
4.3 Registro Técnico por Ferramenta 26
4.3.1 Nmap — Reconhecimento de Rede 26
4.3.2 curl — Baseline de Resposta 26
4.3.3 ffuf — Enumeração de Conteúdo 26
4.3.4 dirsearch — Enumeração Complementar 27
4.3.5 Nikto — Varredura de Configurações 27
4.3.6 OWASP ZAP e Burp Suite — Análise de Tráfego HTTP 27
5. MEDIDAS DE CONTROLE E MITIGAÇÃO 28
5.1 Conduta Ética e Escopo dos Testes 28
5.2 Controles Técnicos Aplicados 28
5.3 Plano de Ação Recomendado 28
Prioridade Alta — Implementação Imediata 28
Prioridade Média — Próximos 30 dias 28
Prioridade Estratégica — Próximos 90 dias 28
5.4 Impacto Regulatório — LGPD e Normas Aplicáveis 29
6. CONCLUSÃO ESTRATÉGICA 29

Além do relatório, também foi pedido um vídeo não listado no YouTube, segue o link: https://youtu.be/VNIARMwrBuQ

1. ETAPA DE RECONHECIMENTO E VERIFICAÇÃO DE PORTAS

1.1 Objetivo

Esta etapa teve como objetivo realizar o reconhecimento inicial da superfície de ataque do alvo dev.pedreira.org. O reconhecimento (fase de recon) é o estágio inicial de qualquer avaliação de segurança profissional, equivalente a um levantamento cartográfico antes de uma operação — sem ele, o analista opera às cegas. Foi também desenvolvido um script em Shell reunindo os principais comandos da coleta preliminar de informações.

Objetivos desta fase:

- Verificar a disponibilidade do host (se o servidor está online e respondendo)
- Confirmar a resolução DNS (se o domínio aponta para o endereço IP correto)
- Mapear portas acessíveis e serviços em execução
- Identificar versões dos softwares expostos (fingerprinting)
- Compreender o comportamento inicial da aplicação web

Todas as atividades foram realizadas a partir de uma máquina virtual Kali Linux — sistema operacional padrão da indústria para testes de segurança.

1.2 Verificação de Conectividade – Ping

O primeiro teste verificou se o host alvo respondia a requisições ICMP (protocolo utilizado pelo comando ping para checar a disponibilidade de um servidor).

```
ping -c 4 dev.pedreira.org
```

O teste resultou em 100% de perda de pacotes. Este comportamento, no entanto, não indica que o servidor esteja offline.

> **Nota Técnica:**
> Em muitos ambientes corporativos e de produção, regras de firewall bloqueiam requisições ICMP por motivos de segurança. A ausência de resposta ao ping não determina a indisponibilidade do servidor — apenas confirma que esse protocolo específico está filtrado.

1.3 Verificação de Resolução DNS – Nslookup

Foi realizada uma consulta DNS (Sistema de Nomes de Domínio — sistema responsável por traduzir nomes de domínio em endereços IP numéricos) para confirmar a configuração correta do domínio.

```
nslookup dev.pedreira.org
```

A ferramenta confirmou que o domínio está corretamente configurado e resolvendo para um endereço IP válido, garantindo que as varreduras subsequentes sejam direcionadas ao servidor correto.

1.4 Varredura de Portas – Nmap

Após confirmar a resolução DNS, foi realizada uma varredura de portas com o Nmap — ferramenta de referência global para análise de redes e reconhecimento de superfície.

```
nmap -sS -sV -T3 -p- dev.pedreira.org
```

Descrição dos parâmetros utilizados:

Parâmetro	Função
-sS	SYN Scan (Stealth Scan) — varredura furtiva que não completa a conexão TCP, reduzindo chances de detecção
-sV	Identifica a versão dos serviços em execução nas portas abertas (fingerprinting de serviço)
-T3	Velocidade moderada de varredura, reduzindo impacto na infraestrutura e chance de alertas de segurança
-p-	Varredura em todas as 65.535 portas TCP disponíveis (cobertura total)

Resultados obtidos:

- 65.533 portas TCP estão filtradas — indica presença de firewall ativo
- 2 portas abertas identificadas com serviços web:

Porta	Serviço	Descrição
80	HTTP	Servidor web — redireciona automaticamente para HTTPS
443	HTTPS	Servidor web com criptografia SSL/TLS — porta principal da aplicação

Ambas as portas executam HAProxy versão 2.0.0 — software de balanceamento de carga e proxy reverso que distribui requisições entre servidores backend.

1.5 Validação de Conectividade – Netcat

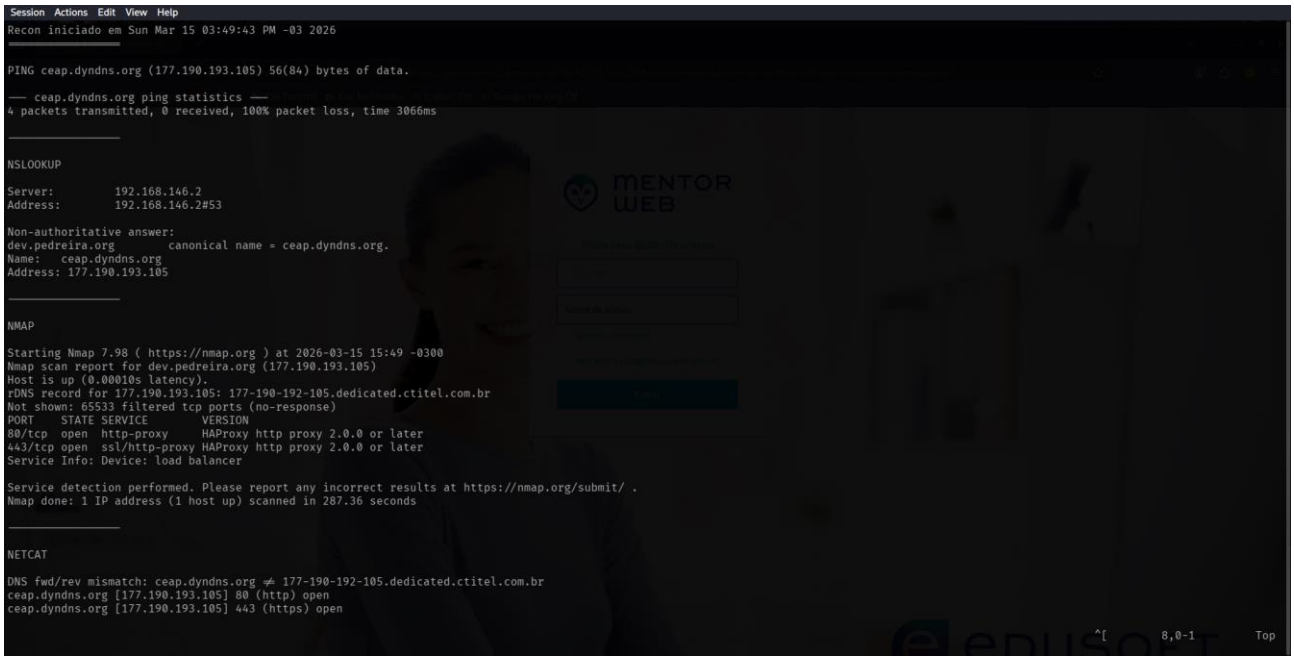
Para confirmar os resultados do Nmap, o Netcat (ferramenta conhecida como o 'canivete suíço das redes') foi utilizado para testar conexões TCP diretamente nas portas identificadas.

```
nc -zv dev.pedreira.org 80,443
```

Parâmetro	Função
-z	Realiza apenas o teste de conexão sem transmitir dados (conexão silenciosa de verificação)
-v	Modo verboso — exibe detalhes da tentativa de conexão

Resultado: As portas 80 e 443 estão acessíveis e aceitam conexões TCP — validando os resultados do Nmap.

O resultado final dos comandos realizados nesta etapa de recon estão demonstrados abaixo na imagem.



1.6 Análise Inicial da Aplicação Web

Com as portas confirmadas, foi realizado o acesso manual à aplicação por meio dos navegadores Mozilla Firefox e Google Chrome, garantindo consistência na análise. O servidor redireciona automaticamente para:

```
https://dev.pedreira.org/devSecurityG5/?pcaes=a205de9c60d3992e6296830743168a74
```

1.7 Comportamento de Redirecionamento e Parâmetro pcaes

Durante o acesso inicial foram observados dois comportamentos relevantes:

- A aplicação está hospedada no diretório /devSecurityG5/ — informação valiosa para a fase de enumeração
- A URL contém um parâmetro GET denominado pcaes com valor hexadecimal de 32 caracteres

A modificação manual do valor do parâmetro “pcaes” não afetou o funcionamento da autenticação, não influenciou diretamente o comportamento da aplicação. Elementos visuais, como imagens de fundo, são alterados mesmo sem modificação do parâmetro, apenas com o recarregamento da página. Portanto não foi identificada relação consistente entre o valor do parâmetro e o conteúdo renderizado.

Esses resultados indicam que a variação visual observada está associada ao comportamento dinâmico da aplicação (ex.: rotação de imagens ou carregamento randômico), e não ao valor do parametro pcaes.

Dessa forma, até o momento da análise, o parâmetro foi classificado como:

- **não influente no comportamento funcional da aplicação**
- **sem evidência de impacto direto na segurança**

Ainda assim, sua presença pode ser considerada relevante para futuras análises, especialmente em testes mais aprofundados de manipulação de parâmetros e controle de fluxo daaplicação.

1.8 Conclusão da Fase de Reconhecimento

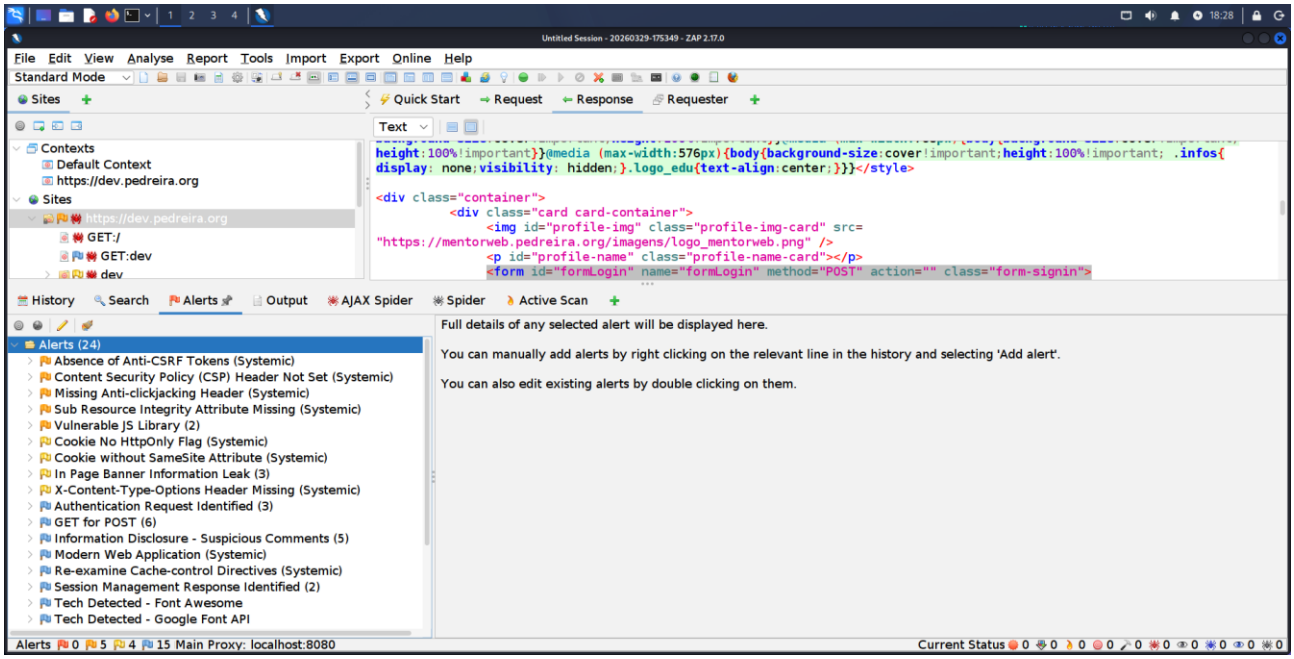
A fase de reconhecimento forneceu um mapeamento claro da superfície de ataque disponível:

- Host responde a consultas DNS — servidor online e operacional
- Requisições ICMP bloqueadas — firewall ativo confirmado
- Apenas portas 80 e 443 expostas — superfície de ataque reduzida
- HAProxy v2.0.0 identificado como proxy reverso (servidores backend ocultos)
- Aplicação hospedada em /devSecurityG5/ com página de login pública
- Parâmetro GET pcaes identificado e documentado para análises futuras

2. ANÁLISE DE VULNERABILIDADES WEB – OWASP ZAP E BURP SUITE

2.1 Visão Geral dos Achados

Nesta fase, foram utilizadas as ferramentas OWASP ZAP (Zed Attack Proxy) e Burp Suite — as duas principais plataformas de análise de segurança web da indústria — para interceptar, analisar e auditar o tráfego HTTP/HTTPS da aplicação. Contudo, seguimos como base as vulnerabilidades mais relevantes, com falhas que podem levar à algum risco possivelmente significativo se exploradas.



2.2 Vulnerabilidade 1 – Cookies sem Flag HttpOnly

Classificação CVSS v3.1

Pontuação CVSS	4.0 (Baixa isoladamente — Moderada em cenário combinado)
Vetor CVSS	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N
Severidade	BAIXA → MODERADA (encadeamento)
Probabilidade	Média (condicionada à existência de XSS)
Compliance (LGPD)	Art. 46 – Medidas de segurança técnica para proteção de dados

O que é e por que importa

O cookie ESR é transmitido ao navegador do usuário sem a flag HttpOnly. Esta flag é uma medida de segurança que instrui o navegador a não permitir que scripts JavaScript acessem o valor do cookie.

> *Tradução executiva: É como deixar um crachá de acesso corporativo em cima de uma mesa em área comum — qualquer script malicioso que passar pode capturá-lo e utilizá-lo para invadir a conta do usuário.*

Vetor de Exploração

Se um atacante conseguir executar código JavaScript no navegador do usuário (via XSS — Cross-Site Scripting), poderá acessar o cookie de sessão através do comando document.cookie e exfiltrá-lo para um servidor externo.

Impacto Potencial

- Sequestro de sessão de usuário autenticado (session hijacking)
- Acesso indevido a contas sem necessidade de credenciais
- Possível escalada para acesso a contas administrativas
- Violação de confidencialidade de dados pessoais — risco LGPD
- Agravamento do impacto em cenários de exploração encadeada com outras falhas da aplicação

Exposição Legal – LGPD

A ausência desta proteção pode caracterizar falha nas medidas técnicas de segurança exigidas pela Lei Geral de Proteção de Dados (Lei nº 13.709/2018), podendo resultar em:

- Multa administrativa de até 2% do faturamento bruto da empresa (limitada a R$ 50.000.000,00 por infração)
- Obrigação de comunicação pública do incidente de segurança
- Danos reputacionais e perda de confiança dos usuários

2.3 Vulnerabilidade 2 – Cookies sem Atributo SameSite

Classificação CVSS v3.1

Pontuação CVSS	4.3
Vetor CVSS	AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Severidade	BAIXA
Probabilidade	Baixa a Média (requer interação do usuário)
Risco Associado	Ataques CSRF (Cross-Site Request Forgery)

O que é e por que importa

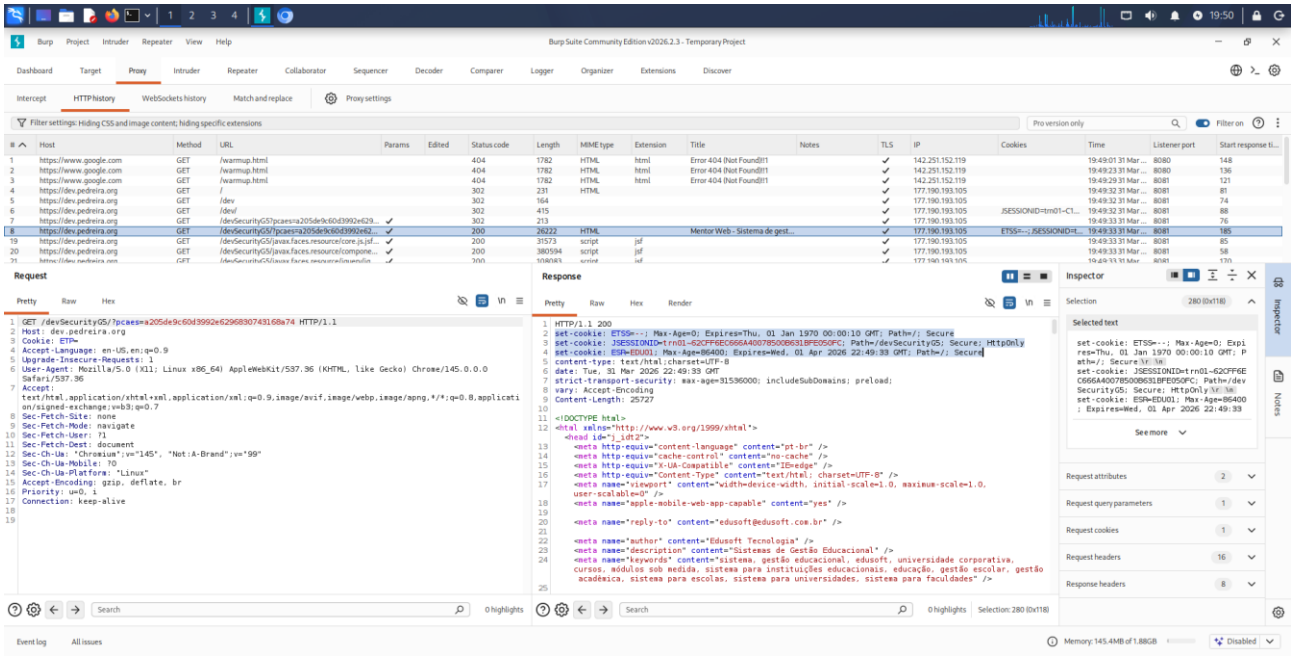
Os cookies **ESR** e **ETSS**, ambos relacionados ao mecanismo de autenticação e gerenciamento de sessão da aplicação, são transmitidos ao navegador do usuário sem a flag **HttpOnly**. Essa flag é uma medida de segurança que instrui o navegador a não permitir que scripts JavaScript acessem o valor desses cookies.

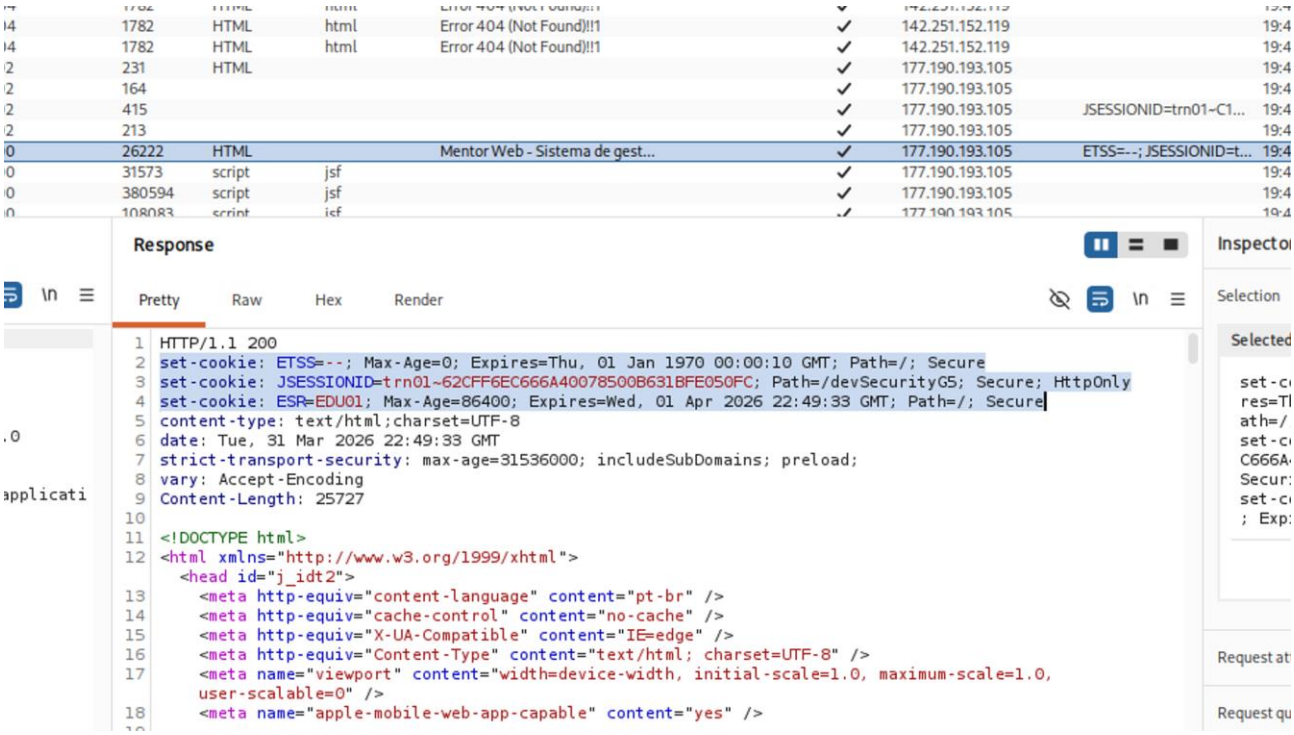
Na ausência dessa proteção, caso exista uma vulnerabilidade client-side, como **Cross-Site Scripting (XSS)**, scripts maliciosos poderão acessar esses identificadores e utilizá-los de forma indevida, aumentando o risco de comprometimento da sessão do usuário autenticado.

> *Tradução executiva: É como deixar credenciais de acesso expostas em uma área comum: se um código malicioso conseguir rodar no navegador, ele poderá capturar esses identificadores e reutilizá-los para assumir a sessão do usuário.*

Impacto Potencial

- Ataques CSRF (Cross-Site Request Forgery) — execução de ações em nome do usuário sem seu consentimento
- Manipulação de sessões através de requisições forjadas
- Risco indireto de violação de dados pessoais em operações sensíveis





2.4 Vulnerabilidade 3 – Ausência de Headers de Segurança HTTP

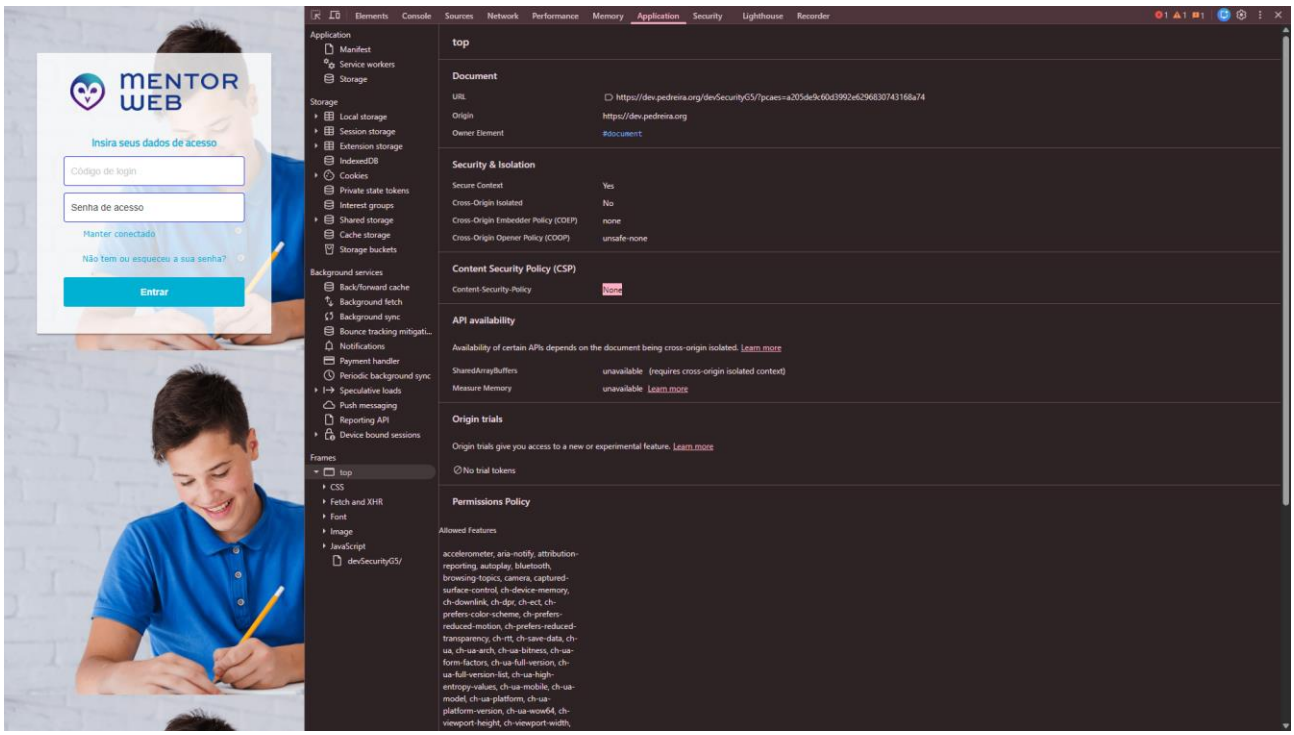
Classificação CVSS v3.1

Pontuação CVSS	5.3
Severidade	MÉDIA
Probabilidade	Média (facilita outros ataques)

Headers ausentes identificados

Header Ausente	Proteção que Deveria Oferecer
Content-Security-Policy (CSP)	Define fontes confiáveis de scripts e recursos — principal defesa contra XSS
X-Frame-Options	Impede carregamento em iframes — proteção contra Clickjacking (fraude visual)
X-Content-Type-Options	Impede interpretação de arquivos com tipo MIME incorreto
Referrer-Policy	Controla informações de origem compartilhadas em requisições externas
Permissions-Policy	Controla acesso a APIs sensíveis (câmera, microfone, geolocalização etc.)

> *Tradução executiva: É como entregar o navegador do usuário sem qualquer regra de segurança — qualquer código externo pode ser executado com liberdade total.*

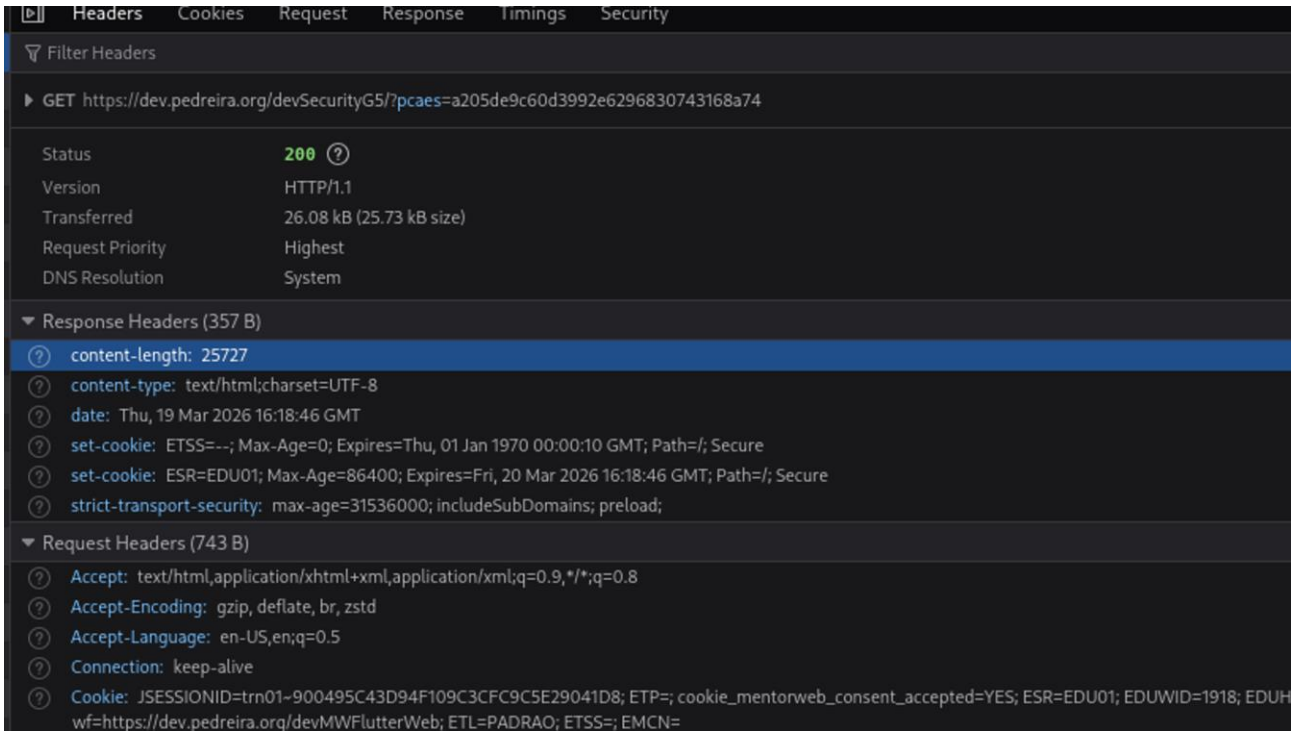


350	script	jsf	✓	177.190.193.105
31573	script	jsf	✓	177.190.193.105
81660	script	jsf	✓	177.190.193.105
11009	script	jsf	✓	177.190.193.105
40591	woff	xhtml	✓	177.190.193.105

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200
2  set-cookie: ETSS=--; Max-Age=0; Expires=Thu, 01 Jan 1970 00:00:10 GMT; Path=/; Secure
3  set-cookie: JSESSIONID=trn01~9FA24D2B2332F6134ED1041055EDFEFC; Path=/devSecurityG5; Secure; HttpOnly
4  set-cookie: ESR=EDU01; Max-Age=86400; Expires=Fri, 20 Mar 2026 16:59:45 GMT; Path=/; Secure
5  content-type: text/html;charset=UTF-8
6  date: Thu, 19 Mar 2026 16:59:44 GMT
7  strict-transport-security: max-age=31536000; includeSubDomains; preload;
8  vary: Accept-Encoding
9  Content-Length: 25727
10
11 <!DOCTYPE html>
12 <html xmlns="http://www.w3.org/1999/xhtml">
     <head id="j_idt2">
13     <meta http-equiv="content-language" content="pt-br" />
14     <meta http-equiv="cache-control" content="no-cache" />
15     <meta http-equiv="X-UA-Compatible" content="IE=edge" />
16     <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
17     <meta name="viewport" content="width=device-width, initial-scale=1.0, maximum-scale=1.0, user-sca
```



2.5 Vulnerabilidade 4 – Biblioteca jQuery 1.11.3 com CVEs Conhecidos

Classificação CVSS v3.1

Pontuação CVSS	6.1
Severidade	MÉDIA
CVEs Associados	CVE-2019-11358, CVE-2020-11022, CVE-2020-11023, CVE-2015-9251
Versão em Uso	jQuery 1.11.3 (lançada em 2015 — mais de 10 anos sem atualização)
Versão Segura Recomendada	jQuery 3.7.x ou superior

O que é e por que importa

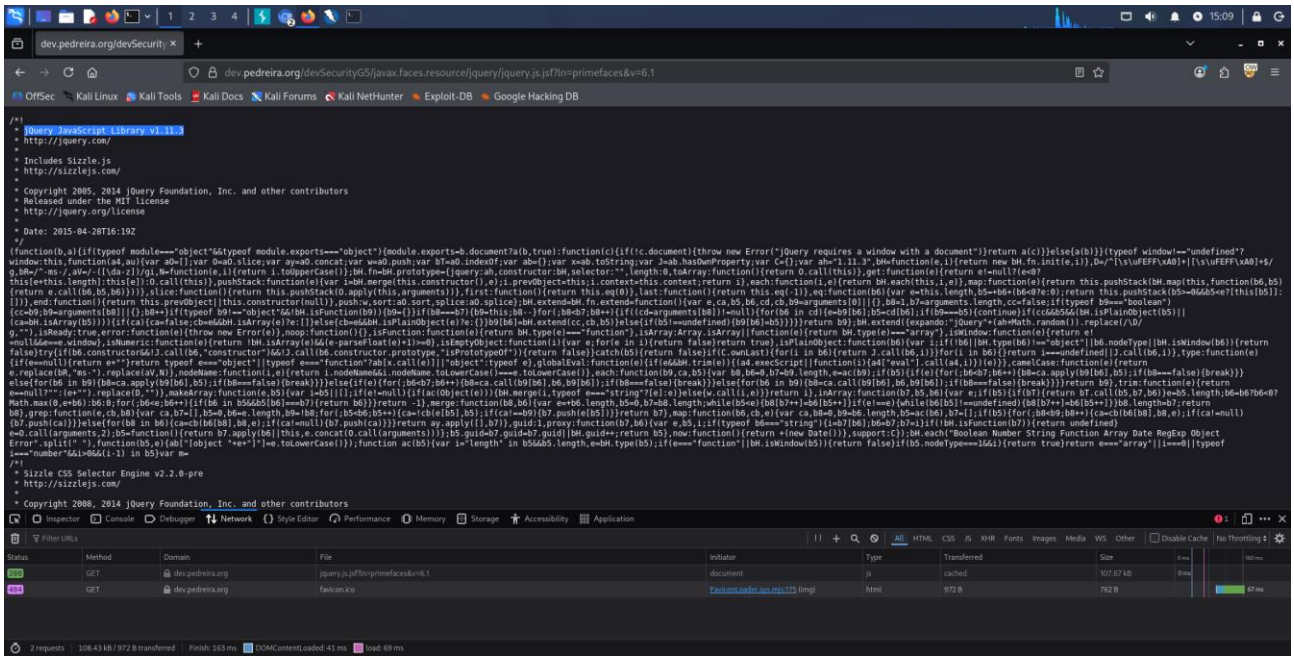
jQuery é uma biblioteca JavaScript amplamente utilizada que simplifica a interação com páginas web. A versão 1.11.3 contém múltiplas vulnerabilidades conhecidas publicamente (CVEs), incluindo falhas que permitem ataques de Cross-Site Scripting (XSS) e Prototype Pollution.

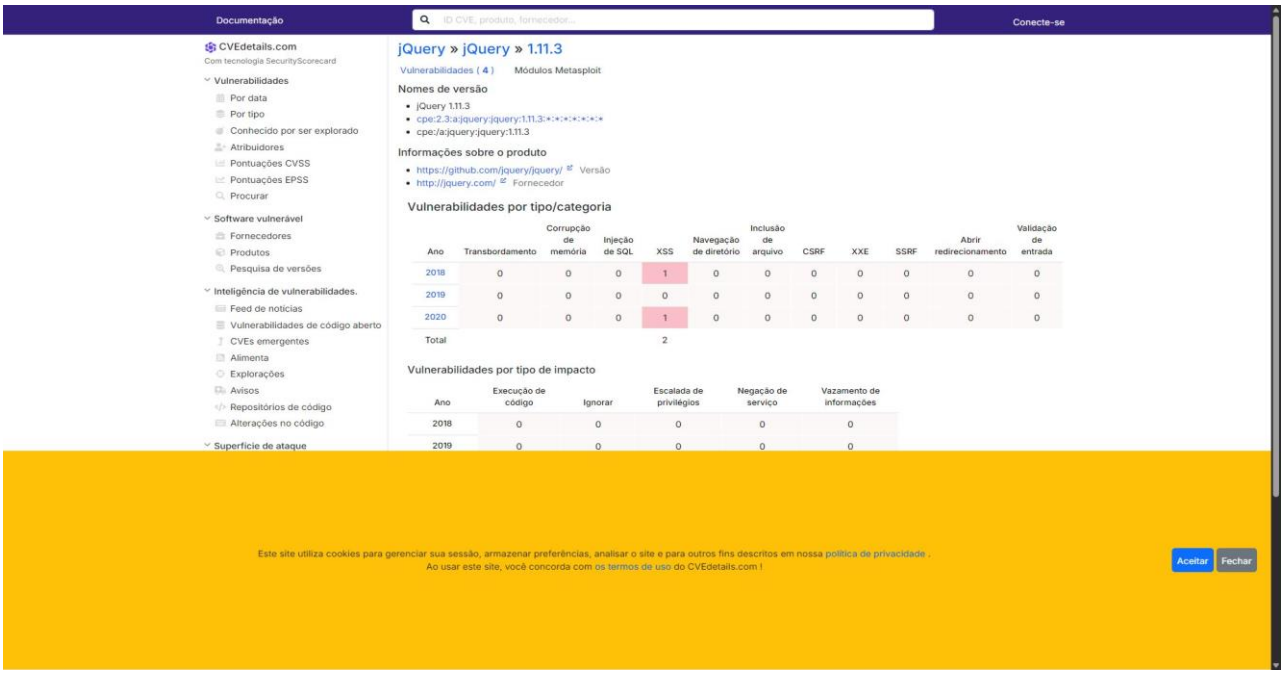
> *Tradução executiva: É equivalente a utilizar um software com falhas de segurança documentadas e publicadas. Qualquer atacante com acesso às bases públicas de CVEs sabe exatamente como explorar estas falhas.*

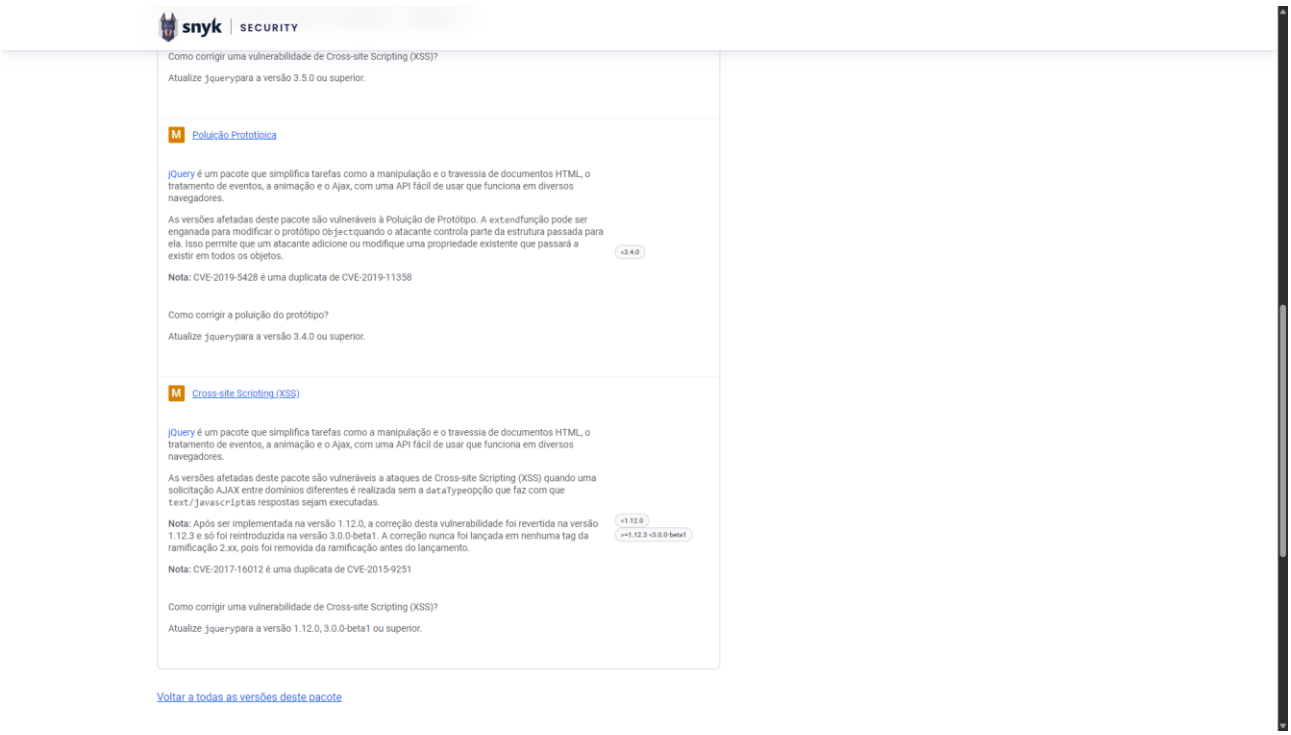
Impacto Potencial

- XSS — execução de código JavaScript malicioso no navegador dos usuários

- Prototype Pollution — contaminação de objetos JavaScript comprometendo a lógica da aplicação
- Manipulação do DOM (Document Object Model – a estrutura da página web) e comprometimento da experiência dos usuários finais







snyk | SECURITY

Como corrigir uma vulnerabilidade de Cross-site Scripting (XSS)?

Atualize `jquery`para a versão 3.5.0 ou superior.

M Poluição Prototípica

jQuery é um pacote que simplifica tarefas como a manipulação e o travessia de documentos HTML, o tratamento de eventos, a animação e o Ajax, com uma API fácil de usar que funciona em diversos navegadores.

As versões afetadas deste pacote são vulneráveis à Poluição de Protótipo. A `extend`função pode ser enganada para modificar o protótipo `Object`quando o atacante controla parte da estrutura passada para ela. Isso permite que um atacante adicione ou modifique uma propriedade existente que passará a existir em todos os objetos. <3.4.0

Nota: CVE-2019-5428 é uma duplicata de CVE-2019-11358

Como corrigir a poluição do protótipo?

Atualize `jquery`para a versão 3.4.0 ou superior.

M Cross-site Scripting (XSS)

jQuery é um pacote que simplifica tarefas como a manipulação e o travessia de documentos HTML, o tratamento de eventos, a animação e o Ajax, com uma API fácil de usar que funciona em diversos navegadores.

As versões afetadas deste pacote são vulneráveis a ataques de Cross-site Scripting (XSS) quando uma solicitação AJAX entre domínios diferentes é realizada sem a `dataType`opção que faz com que `text/javascript`as respostas sejam executadas.

Nota: Após ser implementada na versão 1.12.0, a correção desta vulnerabilidade foi revertida na versão 1.12.3 e só foi reintroduzida na versão 3.0.0-beta1. A correção nunca foi lançada em nenhuma tag da ramificação 2.xx, pois foi removida da ramificação antes do lançamento. <1.12.0 >=1.12.3 <3.0.0-beta1

Nota: CVE-2017-16012 é uma duplicata de CVE-2015-9251

Como corrigir uma vulnerabilidade de Cross-site Scripting (XSS)?

Atualize `jquery`para a versão 1.12.0, 3.0.0-beta1 ou superior.

Voltar a todas as versões deste pacote

2.6 Vulnerabilidade 5 – Ausência de Subresource Integrity (SRI)

Classificação CVSS v3.1

Pontuação CVSS	5.0
Severidade	MÉDIA
Recurso Externo sem SRI	fonts.googleapis.com
Probabilidade	Baixa — porém de altíssimo impacto se explorada

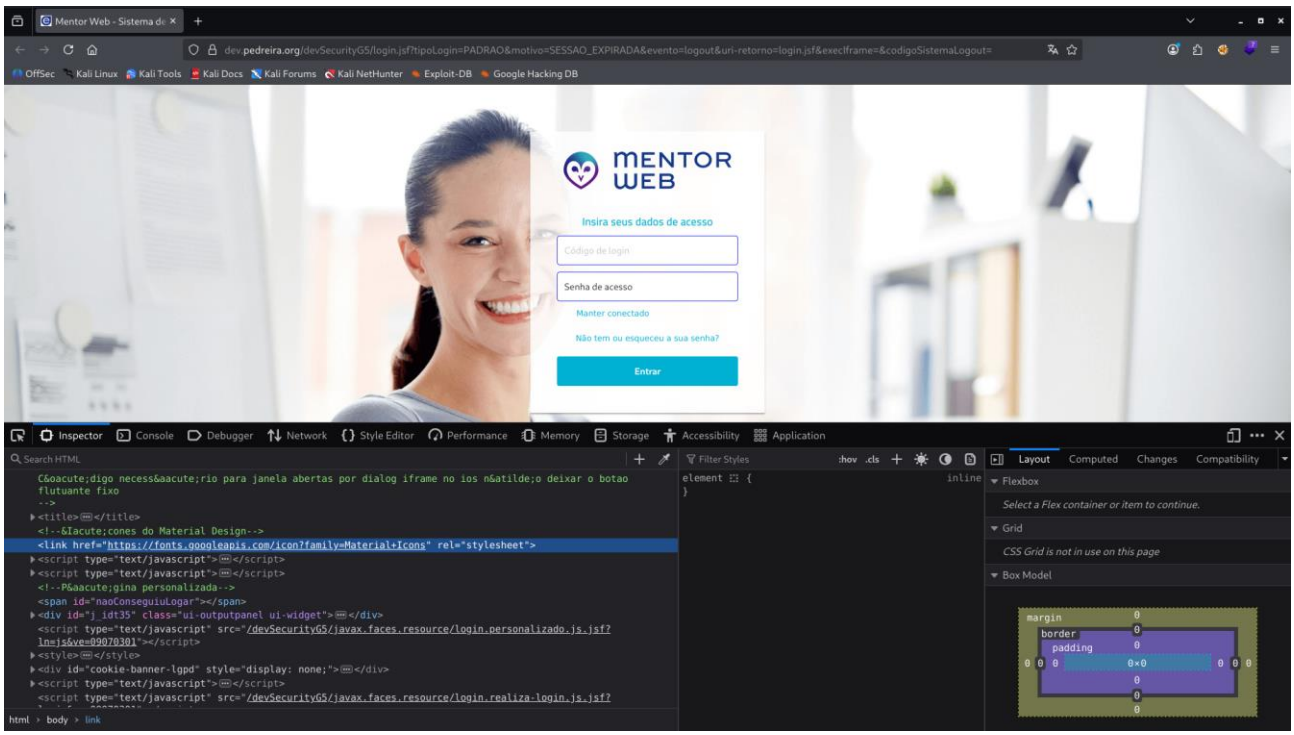
O que é e por que importa

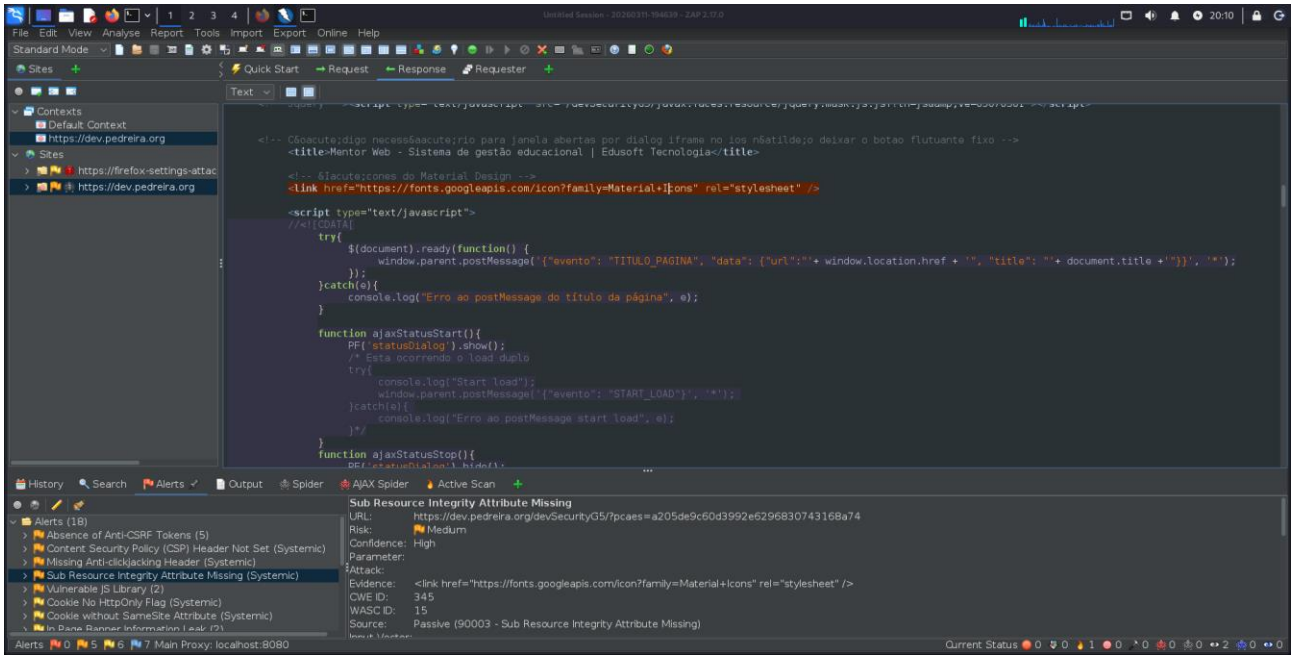
SRI (Subresource Integrity) é um mecanismo que permite ao navegador verificar se recursos carregados de servidores externos não foram alterados. Sem SRI, a aplicação carrega scripts e fontes de terceiros sem qualquer validação de integridade.

> *Tradução executiva: A aplicação importa código de um servidor externo sem verificar se é legítimo. Se esse servidor for comprometido, código malicioso será injetado nos navegadores de todos os usuários simultaneamente — ataque de supply chain.*

Cenário de Ataque — Supply Chain Attack

Em 2021, o comprometimento da biblioteca Polyfill.io afetou mais de 100.000 sites simultaneamente. A ausência de SRI deixa a aplicação vulnerável a cenário idêntico.





2.7 Cenário de Desastre vs. Cenário de Remediação

CENÁRIO DE DESASTRE (não corrigir)	CENÁRIO COM REMEDIAÇÃO (corrigir)
• Falha XSS surge em qualquer módulo da aplicação • Script malicioso é executado no navegador • Cookie ESR é capturado (sem HttpOnly)	• Implementar HttpOnly em todos os cookies • Configurar Content-Security-Policy (CSP) • Atualizar jQuery para versão 3.7.x

• Sessão do usuário é sequestrada • Dados sensíveis são acessados ou manipulados • Incidente reportado — LGPD acionada **Consequências: vazamento de dados, impacto reputacional, investigação regulatória, multa de até R$ 50.000.000,00.**	• Adicionar SameSite=Strict aos cookies • Implementar SRI nos recursos externos • Configurar todos os headers de segurança **Resultado: Redução significativa da superfície de ataque, conformidade com LGPD e ISO 27001, menor risco jurídico.**

3. ENUMERAÇÃO E DESCOBERTA DE SUPERFÍCIE

3.1 Objetivo

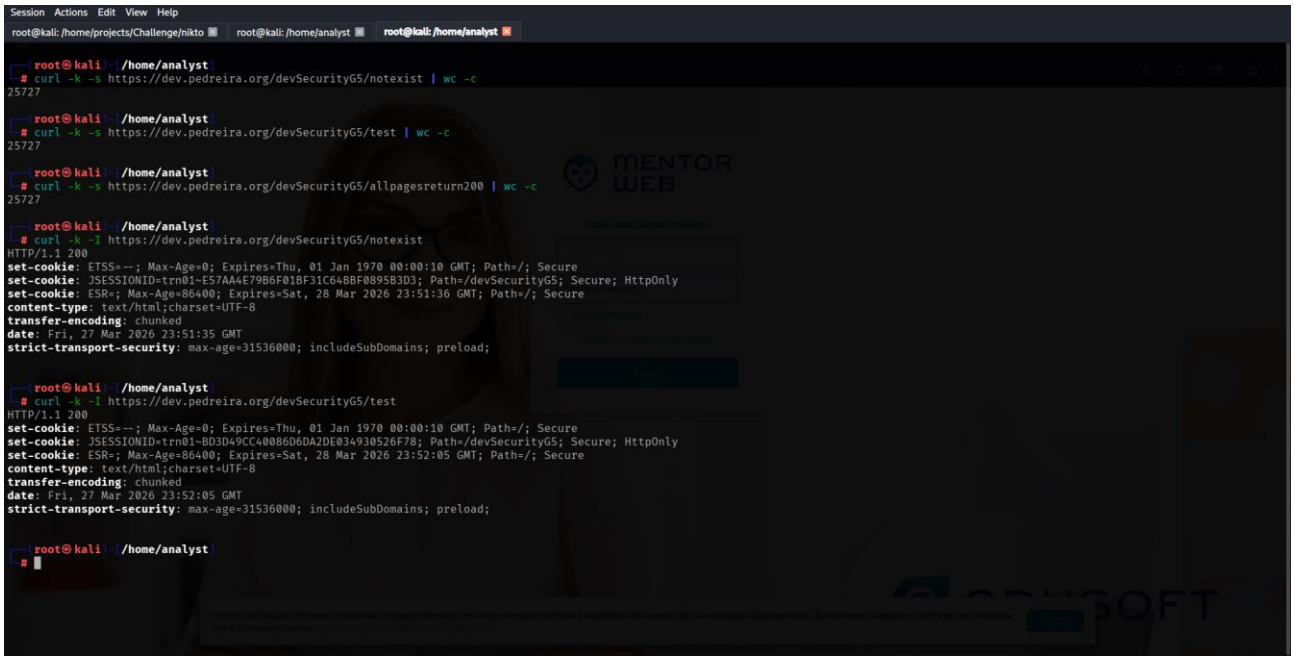
Nesta etapa o objetivo foi identificar diretórios, endpoints e conteúdos potencialmente expostos sem autenticação. Antes das varreduras foi estabelecida uma linha de base (baseline) para evitar falsos positivos — conclusões incorretas sobre a existência de recursos.

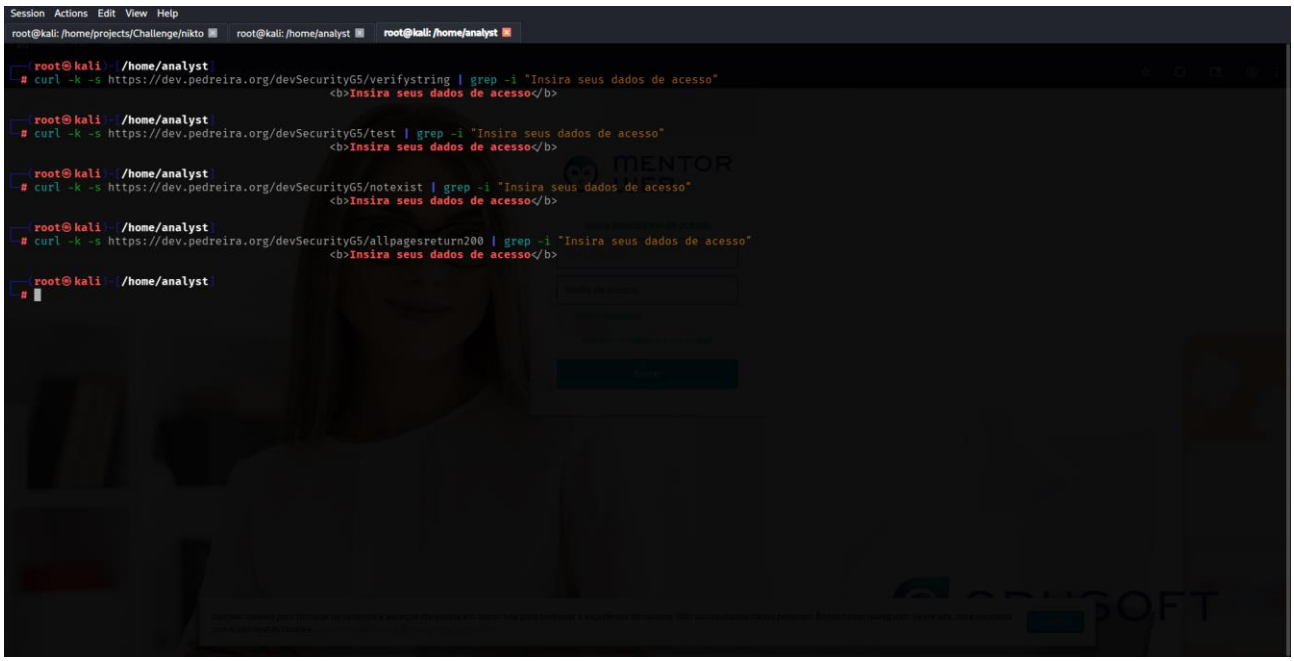
3.2 Linha de Base com curl – Controle de Falsos Positivos

O curl é uma ferramenta de linha de comando para transferência de dados via URL. Foi utilizado para compreender como a aplicação responde a caminhos inexistentes — etapa crítica antes de qualquer ferramenta automatizada de enumeração.

Problema identificado: A aplicação retorna HTTP 200 OK (código que normalmente indica sucesso) para praticamente qualquer caminho — mesmo para recursos que não existem. Isso é chamado de 'soft 404', causaria falsos positivos massivos em ferramentas automatizadas sem controle adequado.

Foram testados múltiplos caminhos arbitrários. Todos os caminhos retornaram HTTP 200 OK com 25.727 bytes e a string 'Insira seus dados de acesso' — confirmando o soft 404. Esse baseline foi usado como filtro em todas as ferramentas subsequentes.





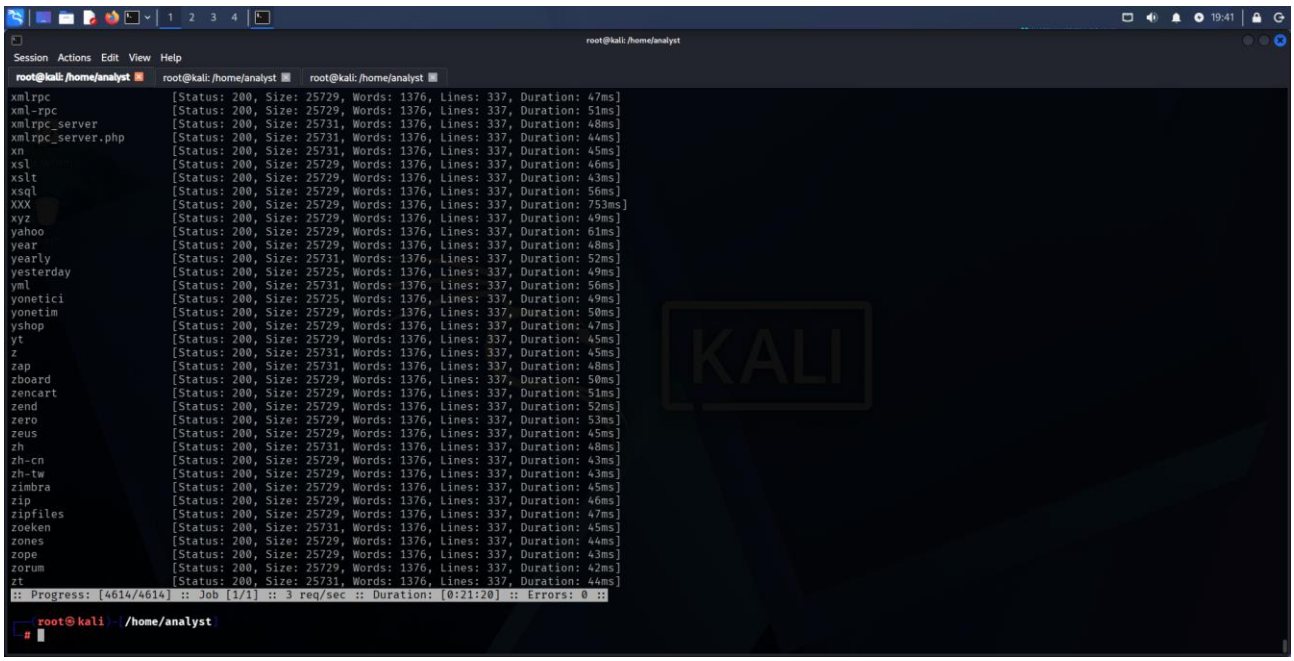
3.3 Enumeração com ffuf

ffuf (Fuzz Faster U Fool) é uma ferramenta de enumeração de alta performance usada para descobrir diretórios e endpoints ocultos. Com base no baseline, foram aplicados filtros rigorosos para eliminar falsos positivos.

```
ffuf -u https://dev.pedreira.org/devSecurityG5/FUZZ -w
/usr/share/wordlists/dirb/common.txt -t 2 -p 0.5 -mc
200,204,301,302,307,401,403 -fs 25727 -k
```

Parâmetro	Função
-t 2	Limita a 2 threads simultâneas (varredura controlada e de baixo impacto)
-p 0.5	Delay de 0,5 segundo entre requisições (reduz impacto no servidor)
-fs 25727	Filtra respostas com exatamente 25.727 bytes (elimina o padrão de soft 404)
-mc	Define os códigos HTTP a serem considerados relevantes
-k	Ignora os erros de certificado SSL (ambiente de desenvolvimento)

Resultado: 4.614 requisições realizadas. Nenhum endpoint com comportamento divergente do baseline foi identificado. A superfície acessível anonimamente é efetivamente limitada.



3.4 Enumeração com dirsearch

O dirsearch foi utilizado como complemento ao ffuf, com extensões ajustadas ao stack tecnológico identificado (JSF/Java).

```
dirsearch -u https://dev.pedreira.org/devSecurityG5/ -e
jsf,js,html,txt,xml,xhtml -t 2 -i 200,204,301,302,307,401,403 -o
dirsearch_devsecurityg5.txt
```

Endpoints identificados:

Endpoint	Código HTTP	Observação
/login	302	Redirecionamento esperado para a página de login
/logout	302	Comportamento padrão de encerramento de sessão
/metrics	200	Resposta diferenciada — exposição de informações internas
/monitoring	401	Endpoint protegido por autenticação HTTP

```
Session  Actions  Edit  View  Help
root@kali: /home/analyst   root@kali: /home/analyst   root@kali: /home/analyst

┌──(analyst㉿kali)-[~]
└─$ sudo su
[sudo] password for analyst:
┌──(root㉿kali)-[/home/analyst]
└─# dirsearch -u https://dev.pedreira.org/devSecurityG5/ \
-e jsf,js,html,txt,xml,xhtml \
-t 2 \
-i 200,204,301,302,307,401,403 \
-o dirsearch_devsecurityg5.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: jsf, js, html, txt, xml, xhtml | HTTP method: GET | Threads: 2 | Wordlist size: 12055

Output File: dirsearch_devsecurityg5.txt

Target: https://dev.pedreira.org/

[18:36:58] Starting: devSecurityG5/
[18:37:07] 302 -    0B  - /devSecurityG5/..;/  →  https://dev.pedreira.org/devSecurityG5/..;/dev
[18:51:07] 302 -    0B  - /devSecurityG5/login  →  https://dev.pedreira.org/devSecurityG5/login.jsf
[18:51:18] 302 -    0B  - /devSecurityG5/logout  →  /devSecurityG5/login.jsf?tipoLogin=PADRAO&motivo=SESSAO_DESTRUIDA_POR_USUARIO&evento=logout
[18:51:51] 200 -  216B  - /devSecurityG5/metrics
[18:52:07] 401 -  720B  - /devSecurityG5/monitoring

Task Completed

┌──(root㉿kali)-[/home/analyst]
└─#
```

Análise Crítica do Endpoint /metrics (HTTP 200 – Público)

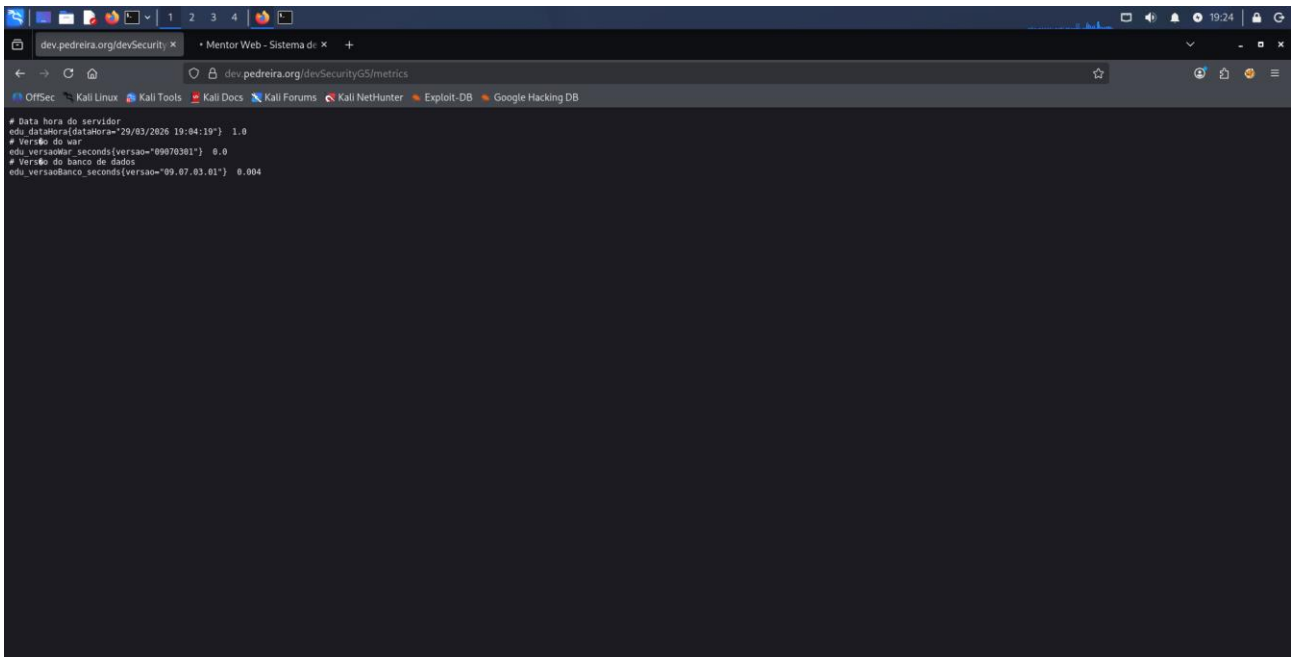
O endpoint /metrics retornou conteúdo estruturado contendo informações internas da aplicação sem exigir qualquer autenticação:

- Data e hora do servidor
- Versão do WAR da aplicação (09070301)
- Versão do banco de dados (09.07.03.01)

Impacto: Embora estes dados não sejam diretamente sensíveis (como senhas), eles são extremamente valiosos para um atacante nas fases de reconhecimento e planejamento de ataque. Conhecendo as versões exatas do sistema e do banco de dados, um atacante pode pesquisar CVEs específicos para estas versões e executar exploits direcionados.

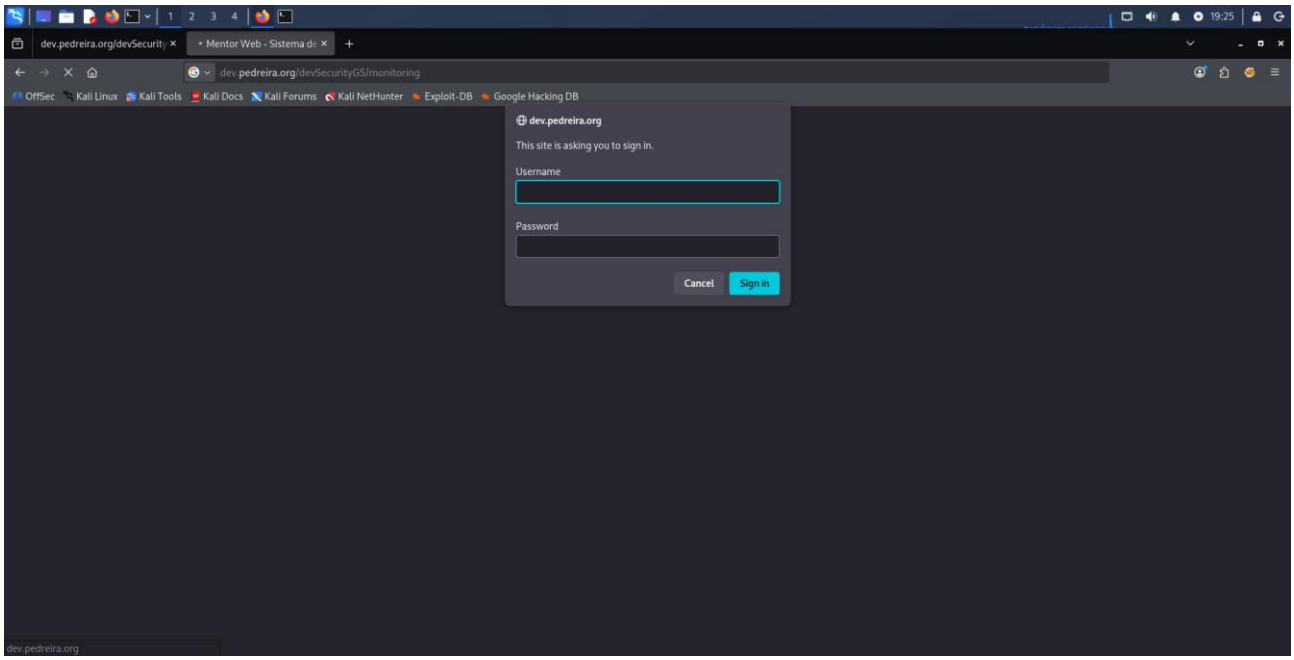
Risco:

Analogia: É como encontrar o manual de manutenção técnica de um cofre jogado na calçada em frente à empresa. O atacante passa a conhecer exatamente as versões do sistema e pode pesquisar CVEs específicos para executar exploits direcionados.



Análise do Endpoint /monitoring (HTTP 401 – Protegido)

O endpoint /monitoring apresenta proteção por autenticação HTTP básica (prompt de login do navegador). Embora protegido, a simples existência e descoberta deste endpoint é relevante — confirma a presença de uma área de monitoramento/administração que, se comprometida, pode expor toda a infraestrutura operacional da aplicação.



3.5 Varredura Complementar com Nikto

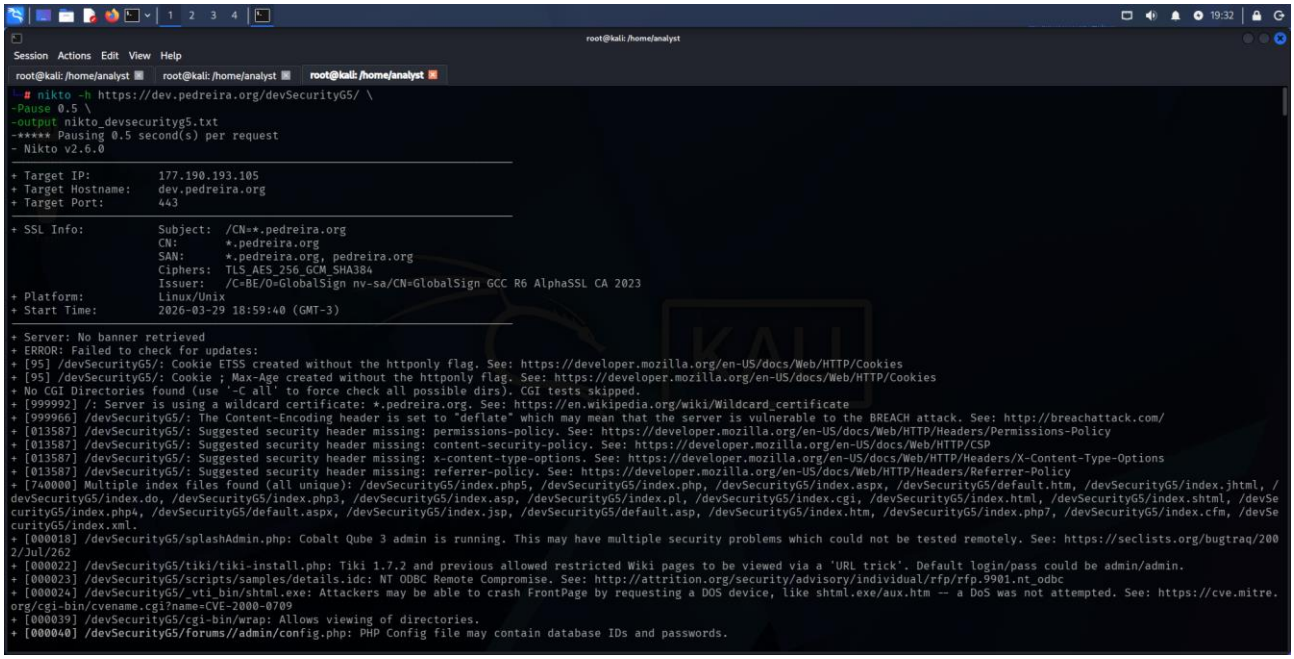
O Nikto é um scanner de servidores web que verifica automaticamente centenas de configurações incorretas, headers ausentes e potenciais exposições conhecidas. Foi utilizado como mecanismo de validação e complementação dos achados anteriores.

```
nikto -h https://dev.pedreira.org/devSecurityG5/ -Pause 0.5 -output
nikto_devsecurityg5.txt
```

Achados validados pelo Nikto (após descarte de falsos positivos):

- Cookie ETSS e ESR criados sem a flag HttpOnly (confirmando achados do Burp Suite, onde apenas o ESR aparentou estar a flag)
- Content-Encoding configurado como 'deflate' — possível exposição ao ataque BREACH (comprometimento de dados em conexões HTTPS comprimidas)
- Headers de segurança ausentes: permissions-policy, content-security-policy, x-content-type-options, referrer-policy

> **Nota Metodológica:**
> O Nikto gerou alto volume de resultados, incluindo referências a arquivos inexistentes e vulnerabilidades genéricas sem evidência concreta. Todos os achados foram validados manualmente antes de serem incluídos neste relatório.



```
root@kali: /home/analyst
Session  Actions  Edit  View  Help
root@kali: /home/analyst   root@kali: /home/analyst   root@kali: /home/analyst
└─# nikto -h https://dev.pedreira.org/devSecurityG5/ \
-Pause 0.5 \
-output nikto_devsecurityg5.txt
-***** Pausing 0.5 second(s) per request
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          177.190.193.105
+ Target Hostname:    dev.pedreira.org
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:           Subject:  /CN=*.pedreira.org
                      CN:       *.pedreira.org
                      SAN:      *.pedreira.org, pedreira.org
                      Ciphers:  TLS_AES_256_GCM_SHA384
                      Issuer:   /C=BE/O=GlobalSign nv-sa/CN=GlobalSign GCC R6 AlphaSSL CA 2023
+ Platform:           Linux/Unix
+ Start Time:         2026-03-29 18:59:40 (GMT-3)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ ERROR: Failed to check for updates:
+ [95] /devSecurityG5/: Cookie ETSS created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [95] /devSecurityG5/: Cookie ; Max-Age created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999992] /: Server is using a wildcard certificate: *.pedreira.org. See: https://en.wikipedia.org/wiki/Wildcard_certificate
+ [999966] /devSecurityG5/: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ [013587] /devSecurityG5/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /devSecurityG5/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /devSecurityG5/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /devSecurityG5/: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [740000] Multiple index files found (all unique): /devSecurityG5/index.php5, /devSecurityG5/index.php, /devSecurityG5/index.aspx, /devSecurityG5/default.htm, /devSecurityG5/index.jhtml, /
devSecurityG5/index.do, /devSecurityG5/index.php3, /devSecurityG5/index.asp, /devSecurityG5/index.pl, /devSecurityG5/index.cgi, /devSecurityG5/index.html, /devSecurityG5/index.shtml, /devSe
curityG5/index.php4, /devSecurityG5/default.aspx, /devSecurityG5/index.jsp, /devSecurityG5/default.asp, /devSecurityG5/index.htm, /devSecurityG5/index.php7, /devSecurityG5/index.cfm, /devSe
curityG5/index.xml.
+ [000018] /devSecurityG5/splashAdmin.php: Cobalt Qube 3 admin is running. This may have multiple security problems which could not be tested remotely. See: https://seclists.org/bugtraq/200
2/Jul/262
+ [000022] /devSecurityG5/tiki/tiki-install.php: Tiki 1.7.2 and previous allowed restricted Wiki pages to be viewed via a 'URL trick'. Default login/pass could be admin/admin.
+ [000023] /devSecurityG5/scripts/samples/details.idc: NT ODBC Remote Compromise. See: http://attrition.org/security/advisory/individual/rfp/rfp.9901.nt_odbc
+ [000024] /devSecurityG5/_vti_bin/shtml.exe: Attackers may be able to crash FrontPage by requesting a DOS device, like shtml.exe/aux.htm -- a DoS was not attempted. See: https://cve.mitre.
org/cgi-bin/cvename.cgi?name=CVE-2000-0709
+ [000039] /devSecurityG5/cgi-bin/wrap: Allows viewing of directories.
+ [000040] /devSecurityG5/forums//admin/config.php: PHP Config file may contain database IDs and passwords.
```

4. FICHA TÉCNICA DOS TESTES

4.1 Objetivo

Esta seção documenta de forma detalhada e auditável todos os comandos executados, versões das ferramentas, parâmetros utilizados e controles aplicados, garantindo reprodutibilidade, rastreabilidade e auditabilidade completa das atividades realizadas.

4.2 Ambiente de Execução

Sistema Operacional	Kali Linux (apt update && apt full-upgrade -y antes dos testes)
Tipo de Ambiente	Máquina Virtual dedicada para testes
Finalidade	Testes controlados em ambiente de homologação
Alvo Principal	https://dev.pedreira.org
Diretório da Aplicação	/devSecurityG5/
Tecnologia Identificada	Java / JSF (JavaServer Faces) com HAProxy 2.0.0

4.3 Registro Técnico por Ferramenta

4.3.1 Nmap — Reconhecimento de Rede

```
nmap -sS -sV -T3 -p- dev.pedreira.org
nc -zv dev.pedreira.org 80,443
```

Resultado: 65.533 portas filtradas; portas 80 (HTTP) e 443 (HTTPS) abertas; serviço HAProxy 2.0.0 identificado.

4.3.2 curl — Baseline de Resposta

```
curl -k -s https://dev.pedreira.org/devSecurityG5/notexist | wc -c
curl -k -s https://dev.pedreira.org/devSecurityG5/test | wc -c
curl -k -s https://dev.pedreira.org/devSecurityG5/allpagesreturn200 | wc -c
curl -k -I curl -k -s https://dev.pedreira.org/devSecurityG5/notexist
curl -k -I curl -k -s https://dev.pedreira.org/devSecurityG5/test
curl -k -s https://dev.pedreira.org/devSecurityG5/verifystring | grep -i
"Insira seus dados de acesso"
curl -k -s https://dev.pedreira.org/devSecurityG5/test | grep -i "Insira seus
dados de acesso"
curl -k -s https://dev.pedreira.org/devSecurityG5/notexist | grep -i "Insira
seus dados de acesso"
curl -k -s https://dev.pedreira.org/devSecurityG5/allpagesreturn200 | grep -i
"Insira seus dados de acesso"
```

Resultado: Todos os caminhos retornam 200 OK com 25.727 bytes e string de login — soft 404 confirmado.

4.3.3 ffuf — Enumeração de Conteúdo

```
ffuf -u https://dev.pedreira.org/devSecurityG5/FUZZ -w
/usr/share/wordlists/dirb/common.txt -t 2 -p 0.5 -mc
200,204,301,302,307,401,403 -fs 25727 -k
```

Resultado: 4.614 requisições; nenhum endpoint relevante identificado fora do padrão.

4.3.4 dirsearch — Enumeração Complementar

```
dirsearch -u https://dev.pedreira.org/devSecurityG5/ -e
jsf,js,html,txt,xml,xhtml -t 2 -i 200,204,301,302,307,401,403 -o
dirsearch_devsecurityg5.txt
```

Resultado: /metrics (200 — exposição informacional), /monitoring (401 — protegido), /login e /logout (302).

4.3.5 Nikto — Varredura de Configurações

```
nikto -h https://dev.pedreira.org/devSecurityG5/ -Pause 0.5 -output
nikto_devsecurityg5.txt
```

Resultado: Confirmação de headers ausentes, cookies sem flags e possível exposição ao ataque BREACH. Alto volume de ruído — validação manual obrigatória aplicada.

4.3.6 OWASP ZAP e Burp Suite — Análise de Tráfego HTTP

Ambas as ferramentas foram configuradas como proxies de interceptação para capturar e analisar o tráfego HTTP/HTTPS entre o navegador e a aplicação. Todos os cookies, headers e respostas foram auditados manualmente.

5. MEDIDAS DE CONTROLE E MITIGAÇÃO

5.1 Conduta Ética e Escopo dos Testes

Todos os testes foram conduzidos exclusivamente no ambiente de homologação autorizado (dev.pedreira.org), respeitando rigorosamente os seguintes princípios:

- Ausência total de brute force (ataque de força bruta para descoberta de senhas)
- Nenhuma modificação de dados da aplicação
- Nenhum payload destrutivo ou que pudesse causar indisponibilidade
- Nenhuma exploração autenticada além do necessário para validação
- Validação manual obrigatória de todos os achados antes de classificação
- Limitação explícita de taxa e concorrência em todas as ferramentas

5.2 Controles Técnicos Aplicados

Ferramenta	Controles de Impacto Aplicados
Nmap	Velocidade T3 (moderada), sem scripts agressivos
ffuf	2 threads, delay 0.5s, filtro por tamanho de resposta
dirsearch	2 threads, filtro de extensões relevantes
Nikto	Pause 0.5s por requisição
Escopo geral	Restrito ao diretório /devSecurityG5/

5.3 Plano de Ação Recomendado

Prioridade Alta — Implementação Imediata

- Implementar Content-Security-Policy (CSP) em todos os headers de resposta
- Ativar flag HttpOnly em todos os cookies de sessão (ETSS, ESR)
- Atualizar jQuery da versão 1.11.3 para 3.7.x ou superior
- Restringir acesso ao endpoint /metrics — exigir autenticação ou removê-lo da área pública

Prioridade Média — Próximos 30 dias

- Adicionar SameSite=Strict ou SameSite=Lax a todos os cookies
- Configurar X-Frame-Options: DENY ou SAMEORIGIN
- Adicionar X-Content-Type-Options: nosniff
- Implementar Referrer-Policy restritiva

Prioridade Estratégica — Próximos 90 dias

- Implementar Subresource Integrity (SRI) em todos os recursos externos
- Inventariar e revisar todas as dependências JavaScript da aplicação
- Criar política formal de atualização de bibliotecas e dependências
- Estabelecer ciclo periódico de testes de segurança (trimestral recomendado)

5.4 Impacto Regulatório — LGPD e Normas Aplicáveis

Norma	Artigo / Referência	Relevância
LGPD — Lei nº 13.709/2018	Art. 46 (segurança), Art. 48 (incidentes), Art. 52 (sanções)	Falhas identificadas podem constituir negligência em segurança de dados pessoais
ISO/IEC 27001:2022	Controles A.8.25 e A.8.28 — Ciclo de vida seguro de software	Uso de componentes desatualizados viola requisitos de desenvolvimento seguro
OWASP Top 10:2021	A05 (Configuração incorreta), A06 (Componentes vulneráveis), A02 (Falhas criptográficas)	Múltiplos itens do Top 10 presentes na aplicação avaliada
NIST SP 800-115	Guia para Testes e Avaliação de Segurança	Metodologia utilizada neste relatório está alinhada a este guia

6. CONCLUSÃO ESTRATÉGICA

Mensagem Final para o Board

A pergunta que precisa ser respondida não é:

"O sistema já foi invadido?"

A pergunta correta é:

"Estamos preparados para quando uma falha inevitável acontecer?"

Hoje, a resposta é: PARCIALMENTE.

Com as correções propostas neste documento, o nível de risco pode ser reduzido de forma rápida, econômica e significativa — muito antes que um incidente real ocorra.

— Fim do Relatório Técnico —

DOCUMENTO CONFIDENCIAL — DISTRIBUIÇÃO RESTRITA